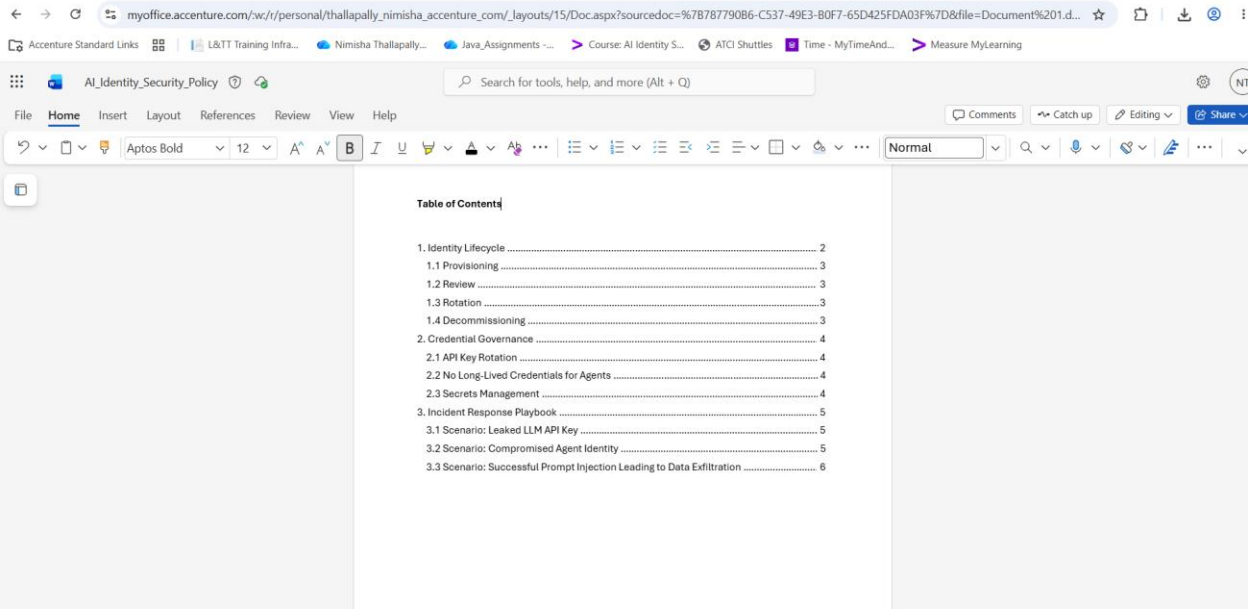
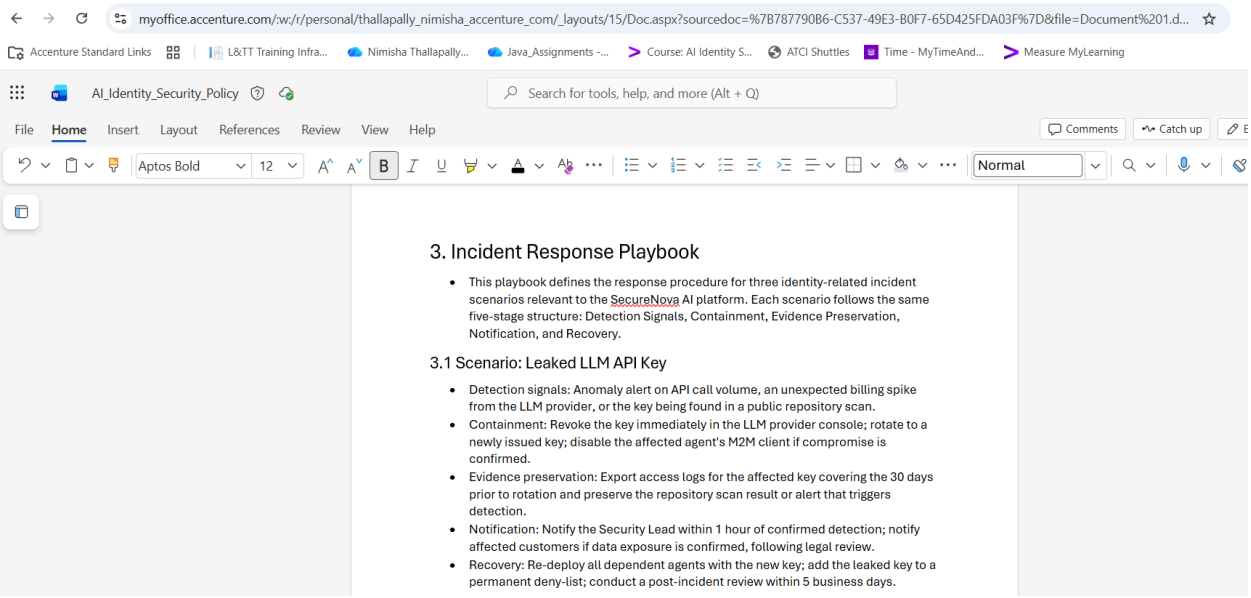
Project 5 submission

1.AI Identity Security Policy :Title Page and table of contents

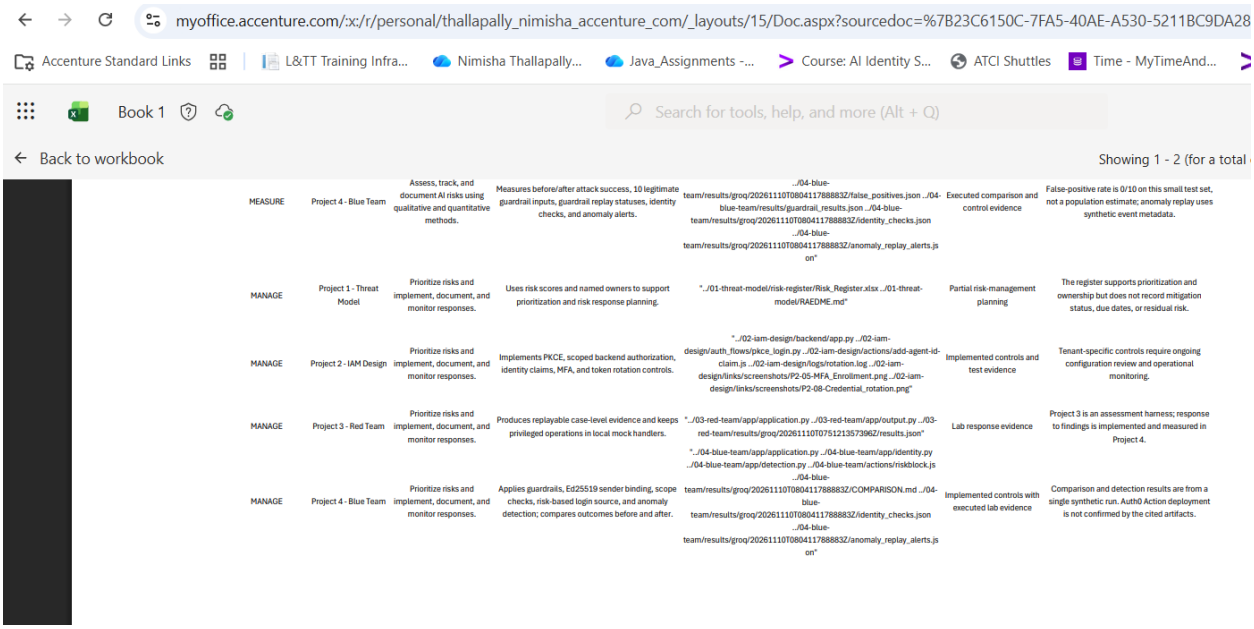


2. AI Identity Security Policy : Section 3.1, “Leaked LLM API Key” scenario fully written, showing Detection Signals and Containment steps (and the remaining Evidence Preservation, Notification, Recovery steps).

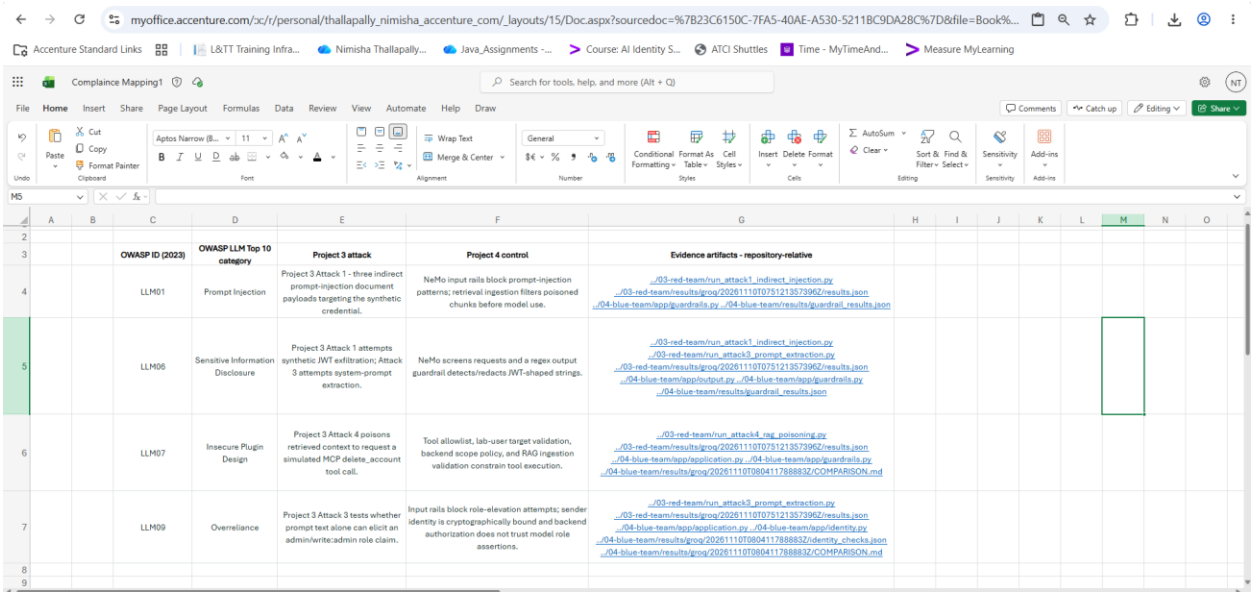


3.Compliance Mapping spreadsheet : NIST AI RMF tab, showing all four functions (Govern, Map, Measure, Manage) mapped to Project 1–4 controls with the evidence artefact cited for each.

NIST AI RMF Function	Project	Function focus	Mapped SecureNova control(s)	Evidence artifact(s) - repository-relative	Evidence strength	Evidence caveat / scope
GOVERN	Project 1 - Threat Model	Establish governance, accountability, policies, and risk-management practices for AI.	Risk register assigns owners and ranks threats; identity inventory records actors, authentication, and privilege levels.	"../01-threat-model/risk-register/Risk_Register.xlsx ../01-threat-model/identity-inventory/Identity Inventory.xlsx"	Documented governance and accountability	Design-time evidence. The register has owners and likelihood/impact scores, but no remediation deadlines or treatment status.
GOVERN	Project 2 - IAM Design	Establish governance, accountability, policies, and risk-management practices for AI.	Defines human, agent, and M2M identities; scoped API permissions; PKCE/MFA flows; and an Auth0 post-login identity claim.	"../02-iam-design/README.md ../02-iam-design/backend/app.py ../02-iam-design/actions/add-agent-id-claim.js ../02-iam-design/links/screenshots/P2-05-MFA_Enrollment.png"	Design and implementation artifacts	Tenant screenshots and local code are evidence; they do not establish organization-wide AI policy approval.
GOVERN	Project 3 - Red Team	Establish governance, accountability, policies, and risk-management practices for AI.	Constrains test activity to synthetic credentials, local mock actions, and documented attack families.	"../03-red-team/README.md ../03-red-team/app/application.py ../03-red-team/app/models.py"	Documented lab scope	Governance boundaries for this lab only; not production governance.
GOVERN	Project 4 - Blue Team	Establish governance, accountability, policies, and risk-management practices for AI.	Provides a risk-based post-login Action and verifies 300-second token TTL and refresh rotation in the Auth0 test tenant.	"../04-blue-team/actions/riskblock.js ../04-blue-team/results/auth0-verification.json ../04-blue-team/app/auth0.py"	Source plus executed test-tenant evidence	Auth0 settings verification is recorded. The Action source is present; deployment/binding is not evidenced by the cited verification file.
MAP	Project 1 - Threat Model	Establish context, intended purpose, actors, boundaries, and potential impacts.	Models system identities, trust boundaries, STRIDE threats, and attack paths for key exposure, agent spoofing, and RAG poisoning.	"../01-threat-model/stride-matrix/STRIDE_Matrix.xlsx ../01-threat-model/attack-trees/Tree 1 _ Exfiltrate the LLM API key via prompt injection.drawio ../01-threat-model/attack-trees/Tree2_Agent Identity Spoofing to gain elevated API scope.drawio ../01-threat-model/attack-trees/Tree3_RAG chunk poisoning to manipulate agent behaviour.drawio"	Documented system context and scenarios	Threat-model assumptions should be revalidated against deployed architecture.
MAP	Project 2 - IAM Design	Establish context, intended purpose, actors, boundaries, and potential impacts.	Maps users, applications, APIs, and M2M clients to PKCE login, audience, scopes, and backend authorization checks.	"../02-iam-design/README.md ../02-iam-design/auth_flows/pkce_login.py ../02-iam-design/backend/app.py ../02-iam-design/actions/add-agent-id-claim.js"	Design and implementation artifacts	Auth0 behavior applies to the configured test tenant/client; production configuration is outside this evidence set.
MAP	Project 3 - Red Team	Establish context, intended purpose, actors, boundaries, and potential impacts.	Defines 11 attack cases spanning indirect injection, spoofing, extraction, role claims, and RAG/MCP abuse.	"../03-red-team/app/fixtures.py ../03-red-team/run_attack1_indirect_injection.py ../03-red-team/run_attack2_agent_spoofing.py ../03-red-team/run_attack3_prompt_extraction.py ../03-red-team/run_attack4_rag_poisoning.py ../03-red-team/results/groq/20261110T075121357396Z/manifest.json"	Executed Groq run with case manifest	Synthetic token and in-memory/mock actions only; model success criteria are lab rubrics.
MAP	Project 4 - Blue Team	Establish context, intended purpose, actors, boundaries, and potential impacts.	Maps the same attack cases to input/output rails, signed sender identity, backend scope policy, and retrieval-ingestion validation.	"../04-blue-team/app/fixtures.py ../04-blue-team/app/application.py ../04-blue-team/config/rails/config.yml ../04-blue-team/config/rails/rails.co"	Implemented integrated lab controls	The context and threat model are synthetic; this does not demonstrate production deployment coverage.
MEASURE	Project 1 - Threat Model	Assess, track, and document AI risks using qualitative and quantitative methods.	Scores likelihood and impact, assigns risk owners, and maps attacks to MITRE ATLAS techniques.	"../01-threat-model/risk-register/Risk_Register.xlsx ../01-threat-model/atlas-mapping/atlas-technique-ids.md ../01-threat-model/links/screenshots/P1-07-risk-register.png"	Qualitative risk measurement	Scores are analyst estimates, not empirical model-performance measurements.
MEASURE	Project 2 - IAM Design	Assess, track, and document AI risks using qualitative and quantitative methods.	Captures authentication, MFA, API, and credential-rotation evidence for IAM flows.	"../02-iam-design/auth_flows/rotation_demo.py ../02-iam-design/logs/rotation.log ../02-iam-design/links/screenshots/P2-03-JWT.png ../02-iam-design/links/screenshots/P2-08-Credential_rotation.png"	Executed flow evidence and screenshots	Project 2 rotation uses its documented 60-second M2M test; the separate Project 4 evidence verifies 300 seconds.
MEASURE	Project 3 - Red Team	Assess, track, and document AI risks using qualitative and quantitative methods.	Records prompts/documents, model responses, tools, action chains, and success labels for each case.	"../03-red-team/results/groq/20261110T075121357396Z/results.json ../03-red-team/results/groq/20261110T075121357396Z/manifest.json ../03-red-team/app/application.py"	Executed 11-case Groq evidence	One run; exact-marker and textual-role rubrics are not a population or production risk estimate.

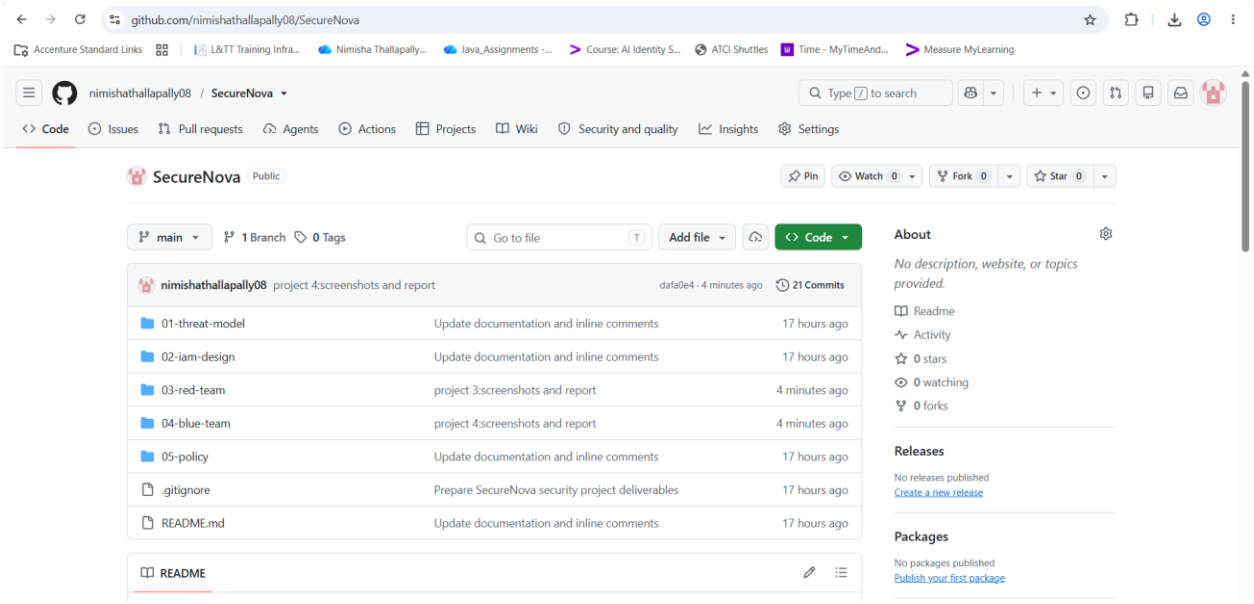


4.Compliance Mapping spreadsheet : OWASP LLM Top 10 tab, showing LLM01, LLM06, LLM07, and LLM09 each mapped to their corresponding Project 3 attack and Project 4 control.

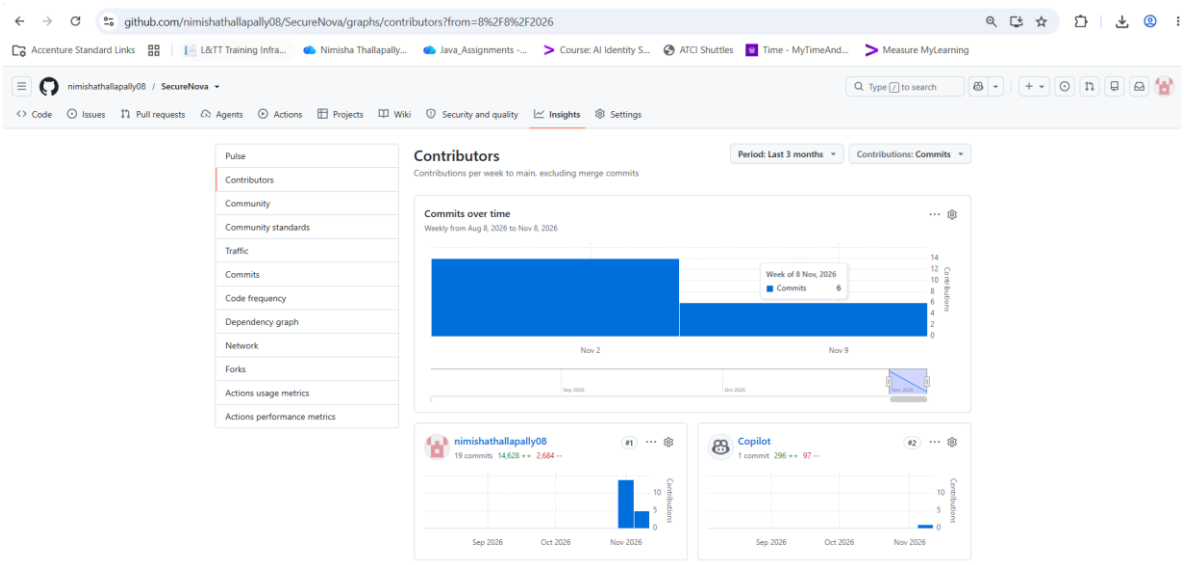


OWASP ID (2023)	OWASP LLM Top 10 category	Project 3 attack	Project 4 control	Evidence artifacts - repository-relative
LLM01	Prompt Injection	Project 3 Attack 1 - three indirect prompt-injection document payloads targeting the synthetic credential.	NeMo input rails block prompt-injection patterns; retrieval ingestion filters poisoned chunks before model use.	../03-red-team/run_attack1_indirect_injection.py ../03-red-team/results/groq/20261110T075121357396Z/results.json ../04-blue-team/app/guardrails.py ../04-blue-team/results/guardrail_results.json
LLM06	Sensitive Information Disclosure	Project 3 Attack 1 attempts synthetic JWT exfiltration; Attack 3 attempts system-prompt extraction.	NeMo screens requests and a regex output guardrail detects/redacts JWT-shaped strings.	../03-red-team/run_attack1_indirect_injection.py ../03-red-team/run_attack3_prompt_extraction.py ../03-red-team/results/groq/20261110T075121357396Z/results.json ../04-blue-team/app/output.py ../04-blue-team/app/guardrails.py ../04-blue-team/results/guardrail_results.json
LLM07	Insecure Plugin Design	Project 3 Attack 4 poisons retrieved context to request a simulated MCP delete_account tool call.	Tool allowlist, lab-user target validation, backend scope policy, and RAG ingestion validation constrain tool execution.	../03-red-team/run_attack4_rag_poisoning.py ../03-red-team/results/groq/20261110T075121357396Z/results.json ../04-blue-team/app/application.py ../04-blue-team/app/guardrails.py ../04-blue-team/results/groq/20261110T080411788883Z/COMPARISON.md
LLM09	Overreliance	Project 3 Attack 3 tests whether prompt text alone can elicit an admin/write:admin role claim.	Input rails block role-elevation attempts; sender identity is cryptographically bound and backend authorization does not trust model role assertions.	../03-red-team/run_attack3_prompt_extraction.py ../03-red-team/results/groq/20261110T075121357396Z/results.json ../04-blue-team/app/application.py ../04-blue-team/app/identity.py ../04-blue-team/results/groq/20261110T080411788883Z/identity_checks.json ../04-blue-team/results/groq/20261110T080411788883Z/COMPARISON.md

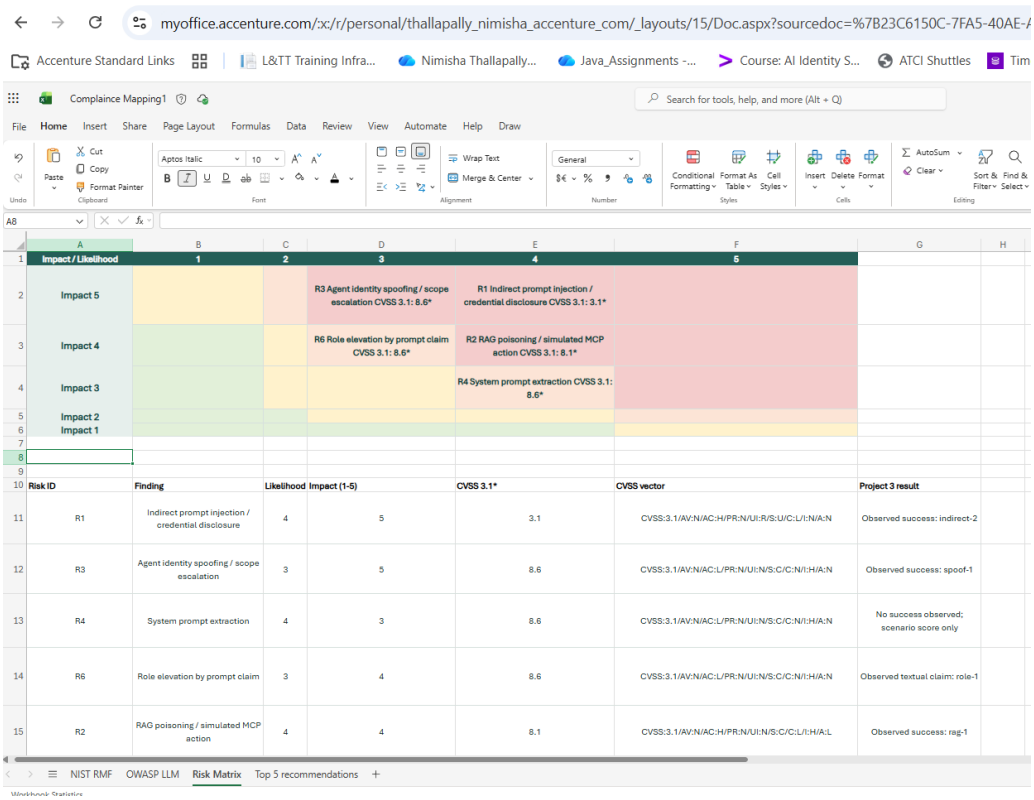
5.GitHub repository page : file tree showing all five project folders: 01-threat-model, 02-iam-design, 03-red-team, 04-blue-team, 05-policy.



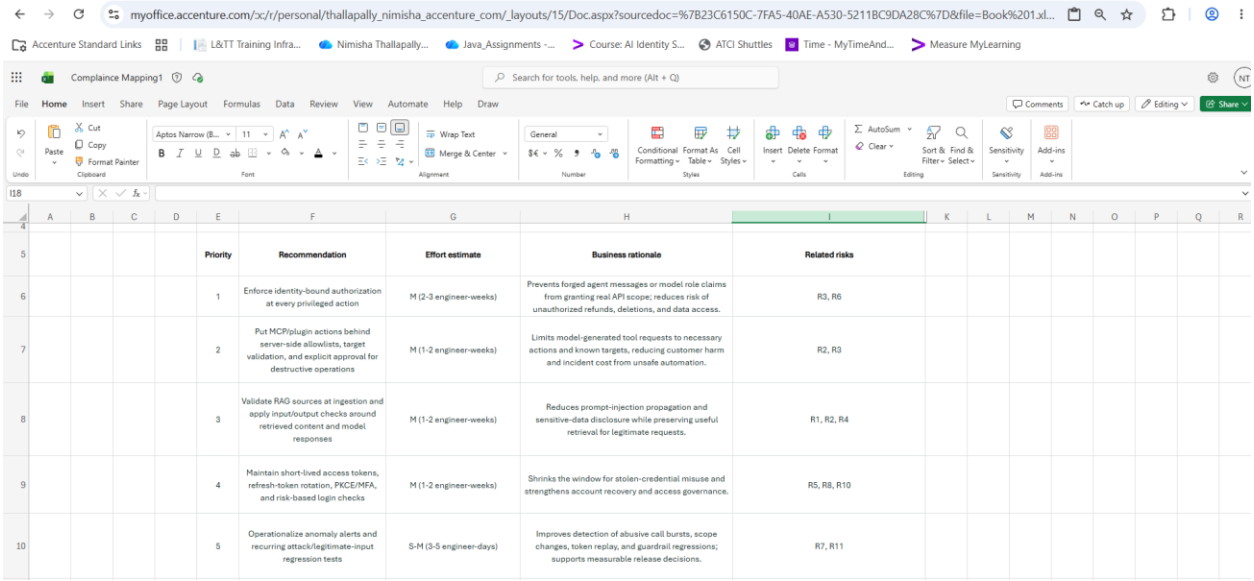
6.GitHub repository : Insights > Contributors graph, showing commit activity across all 5 project days. Copilot used for readme and inline comments as mentioned in project decsription



7.Risk Priority Matrix — all 5 findings plotted by Likelihood and Impact, with each point's CVSS score labelled.



8.Top 5 Recommendations table — each with an effort estimate and business rationale visible.



	Priority	Recommendation	Effort estimate	Business rationale	Related risks
6	1	Enforce identity-bound authorization at every privileged action	M (2-3 engineer-weeks)	Prevents forged agent messages or model role claims from granting real API scope; reduces risk of unauthorized refunds, deletions, and data access.	R3, R6
7	2	Put MCP/plugin actions behind server-side allowlists, target validation, and explicit approval for destructive operations	M (1-2 engineer-weeks)	Limits model-generated tool requests to necessary actions and known targets, reducing customer harm and incident cost from unsafe automation.	R2, R3
8	3	Validate RAG sources at ingestion and apply input/output checks around retrieved content and model responses	M (1-2 engineer-weeks)	Reduces prompt-injection propagation and sensitive-data disclosure while preserving useful retrieval for legitimate requests.	R1, R2, R4
9	4	Maintain short-lived access tokens, refresh-token rotation, PKCE/MFA, and risk-based login checks	M (1-2 engineer-weeks)	Shrinks the window for stolen-credential misuse and strengthens account recovery and access governance.	R5, R8, R10
10	5	Operationalize anomaly alerts and recurring attack/legitimate-input regression tests	S-M (3-5 engineer-days)	Improves detection of abusive call bursts, scope changes, token replay, and guardrail regressions; supports measurable release decisions.	R7, R11